

Conceitos Básicos de Segurança da Informação

Objetivo da Aula

Apresentar os principais conceitos da segurança da informação. Devemos destacar os quatro pontos principais da segurança da informação e dados, que são: confidencialidade, integridade, disponibilidade e autenticidade.

Apresentação

À medida que a dependência da tecnologia cresce em nosso cotidiano, a segurança da informação torna-se uma área cada vez mais crucial no campo da tecnologia da informação. A segurança da informação desempenha um papel fundamental na era digital em que vivemos. Seu objetivo principal é proteger os dados, sistemas e recursos de uma organização contra ameaças cibernéticas, garantindo a confidencialidade, integridade e disponibilidade das informações. Esta apostila explora alguns conceitos básicos desta disciplina, como:

- Confidencialidade;
- Integridade;
- Disponibilidade;
- Autenticação.

Ao compreender estes princípios fundamentais, você estará preparado para criar um ambiente seguro de informação, protegendo-se contra ameaças internas e externas em um mundo digital em constante evolução.

1. Uma Breve História da Segurança de Informação

Tecnologia da informação é, antes de qualquer forma, uma tecnologia de comunicação. Sob certa ótica, podemos afirmar que a segurança da informação tem uma história que remonta às primeiras formas de comunicação e registro de informações. Um evoluiu e

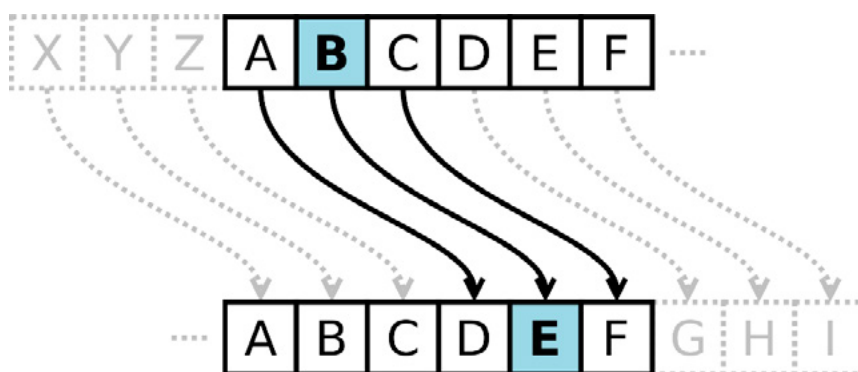
impulsionou o outro, simultaneamente, pois, na medida em que se faz comum um novo tipo de comunicação, se torna necessário criarem medidas de segurança para tal.

A necessidade de proteger informações sensíveis vem desde o tempo dos antigos egípcios. A criptografia nasceu com a utilização de hieróglifos cifrados, que garantiam que mensagens importantes não fossem compreendidas por olhos não autorizados. Dessa forma, garantiam o princípio da confidencialidade.

Ao longo das eras, as cifras e formas de criptografias evoluíram e se tornaram cada vez mais complexas.

A cifra de César, por exemplo, foi uma técnica de substituição, na qual cada letra em uma mensagem era substituída por uma letra deslocada por um número fixo de posições no alfabeto.

Figura 1: Cifra de César



Fonte: Wikipedia. Disponível em: https://pt.wikipedia.org/wiki/Cifra_de_C%C3%A9sar#/media/Ficheiro:Caesar3.svg. Acesso em: 26 jan. 2024.

Dessa forma, utilizando o esquema apresentado na figura 1, a palavra “FACA” seria cifrada para “IDFD”, por exemplo.

O período da Segunda Guerra Mundial, porém se destaca como um grande salto na criptografia com a máquina de codificação alemã chamada Enigma. Enigma era um dispositivo de criptografia eletromecânico que, se ajustado corretamente, conseguia criptografar ou decifrar mensagens. Extremamente sofisticado, uma das maiores conquistas dos países aliados neste período foi a eventual quebra desse dispositivo.

Um dos responsáveis mais famosos pela quebra da criptografia da Enigma é o Alan Turing, um brilhante matemático britânico que criou seu próprio sistema e dispositivo para auxiliar os países aliados a decifrar as mensagens codificadas. Após a guerra, Turing continuou trabalhando em seu sistema e publicou, eventualmente, o design, chamado ACE

(*Automatic Computing Engine*, ou “Motor de Computação Automática”, em tradução livre). O ACE é, discutivelmente, o progenitor da computação moderna. De forma que podemos dizer que Turing é o pai da tecnologia da informação como a conhecemos hoje em dia, apesar de sua participação e importância ter sido mantida secreta até a década de 90.

Pulando algumas décadas, mas ainda lá pelos anos 80, os computadores pessoais e redes de computadores começavam a se fazer mais comuns, então, o governo dos Estados Unidos da América desenvolve um algoritmo de criptografia DES (*Data Encryption Standard*, ou padrão de criptografia de dados em tradução livre). Neste período, surgem os primeiros vírus, como o *Brain Virus*, que explicitavam o potencial de poder destrutivo dos vírus.



Você Sabia?

O *Brain Virus*, também chamado de “*Pakistani Brain*”, foi criado em 1986, por dois irmãos paquistaneses. Ele era um vírus de *boot* no disco rígido ou disquetes. O objetivo dos irmãos não era prejudicar computadores, mas identificar cópias não autorizadas, pois o vírus expunha uma mensagem amigável que informava ao usuário que seu sistema estava infectado e indicava o contato com os criadores para obter assistência. O vírus se espalhou de forma tão eficiente que os irmãos mal aguentavam a quantidade de ligações vindas de diferentes lugares no mundo constantemente para lidar com as infecções.

A popularização da internet, que começou nos anos 90, possibilitou um enorme salto nas ameaças cibernéticas. Se mostra necessário, mais uma vez, um avanço de segurança para deter as ameaças. Então, é criado o SSL (*Secure Sockets Layer*, ou “camada de soquetes seguros”, em tradução livre), originalmente desenvolvido pela Netscape, e então popularizado, em geral. O SSL é um protocolo de segurança utilizado para estabelecer conexões criptografadas seguras entre um cliente e um servidor na internet.

Com o avanço da internet, começam a se evidenciar os outros pilares da segurança, além da confidencialidade. Já no século XXI, com a invenção de nuvens, *streamings* e outros serviços online, é evidenciada a necessidade de garantir a disponibilidade e integridade dos dados entregues aos usuários devidamente autenticados. O foco na segurança da informação aumenta de forma que leva à criação de regulamentações rigorosas de proteção de dados, como o GDPR, na Europa, que depois foi adaptado para o Brasil.

Atualmente, a segurança da informação evolui à medida que as ameaças cibernéticas se sofisticam. A inteligência artificial e o aprendizado de máquina estão sendo usados

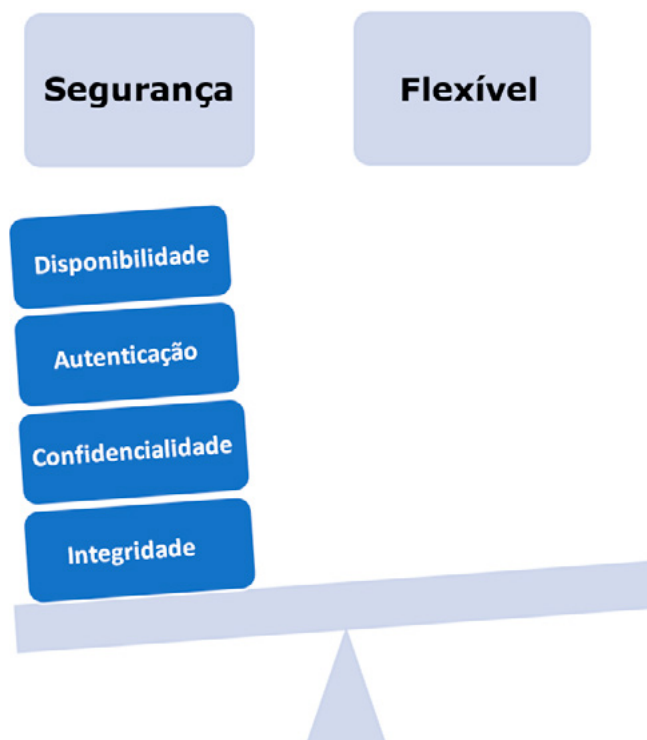
tanto para defender quanto para atacar, enquanto a segurança da informação se torna uma preocupação central em empresas, governos e para indivíduos preocupados com a proteção de seus dados pessoais.

Em resumo, a história da segurança da informação é uma narrativa de constante evolução, impulsionada pelo avanço da tecnologia e pela crescente complexidade das ameaças cibernéticas. A história da segurança da informação é intrínseca a toda evolução dos computadores e dispositivos digitais em geral. A segurança da informação desempenha um papel crítico na proteção de dados e sistemas contra ameaças constantes em um mundo digital altamente conectado.

2. Segurança da Informação

Segurança da informação é uma disciplina dedicada a proteger a confidencialidade, integridade e disponibilidade dos dados e sistemas de informação em uma organização. É uma área multifacetada, que lida com a implementação de medidas e políticas para garantir que as informações sejam protegidas contra ameaças, sejam elas internas ou externas. Abaixo, veremos os pilares (confidencialidade, integridade e disponibilidade), e como esta tríade está intimamente relacionada com a autenticação.

Figura 2: Pilares da Segurança da Informação



Fonte: Elaboração própria (2024).

A figura 2 apresenta os pilares da segurança da informação e mostra que, quanto mais utilizados, mais temos sistemas seguros e menos flexíveis. Temos que destacar também a variável de custo que deve ser considerada, por exemplo, podemos colocar que, para aumentar a disponibilidade, teremos que investir em um site de contingência. Outra visão que devemos ter é que, por exemplo, o aumento da confidencialidade, por meio de criptografia complexa, pode afetar positivamente a integridade dos dados, porém, afetaria negativamente a sua disponibilidade, pois a descryptografia pode exigir mais recursos de processamento.

2.1. Pilares da Segurança da Informação

2.1.1 Confidencialidade

O primeiro pilar, a confidencialidade, costuma ser a primeira e mais comum preocupação daqueles que desejam gerir um ambiente digital seguro. O vazamento de informação de dados pode impactar os negócios de maneiras diferentes, dependendo das circunstâncias em que acontecem. Documentos sigilosos, planos ainda sendo incubados, propriedade intelectual, e até mesmo estratégias de marketing, ao vazarem, podem afetar negativamente a empresa, que sofre ataques à sua confidencialidade. Um problema de confidencialidade é tão ruim quanto parece ser; seus resultados negativos podem ser imediatos ou um pouco atrasados, mas sempre são em detrimento da empresa.

Para proteger a confidencialidade dos dados, as organizações implementam controles de acesso, autenticação e criptografia. Exemplos práticos incluem senhas, autenticação de dois fatores e acesso baseado em função.

2.1.2. Integridade

A integridade visa manter a precisão e a consistência dos dados. Isto significa que os dados não devem ser corrompidos ou alterados de forma não autorizada. Falhas simples não costumam ser muito problemáticas e, em geral, costumam ser fáceis de serem detectadas e corrigidas. Porém, se considerarmos o próximo pilar, a disponibilidade, podemos entender que falhas repetidas ou constantes podem afetar os dados e sistemas, o que podem acarretar problemas sérios com clientes ou disponibilizando informações erradas em algum processo da empresa. Na prática, o número de falhas de integridade está diretamente ligado aos problemas gerados por elas. Ou seja, poucas falhas não são um problema, mas se elas se acumularem, o sistema e a organização perdem a confiança, junto de sua integridade.

Para proteger a integridade, as organizações implementam controles de prevenção de alterações não autorizadas, como assinaturas digitais, controle de versões e **checksums** (o termo **checksum** é utilizado quando temos uma função para analisar dados e verificar se foram ou não modificados).

2.1.3. Disponibilidade

A disponibilidade é essencial para garantir que as informações e sistemas estejam acessíveis sempre que se fazem necessárias. Isto envolve a prevenção de interrupções não planejadas, como ataques de negação de serviço (DDoS) ou falhas de hardware. Considere que utilizamos a internet e sistemas complexos para gerenciar praticamente os pares de uma organização, se o sistema de gerenciamento se torna indisponível, é possível que toda a organização (ou pelo menos setores dela) seja forçada a parar de funcionar até que este problema seja resolvido.

Ataques que afetam a disponibilidade muitas vezes devem ser tratados como prioridade para a máquina organizacional voltar a funcionar corretamente. A prevenção de ataques de disponibilidade é feita não ao impedir o ataque em si, mas ao criar redundâncias de sistemas, **backups** regulares e planos de recuperação em casos de desastres.

2.2. Autenticação

Por fim, a autenticação é um componente crítico da segurança de informação que se concentra na verificação da identidade de usuários e sistemas. Ela garante que apenas indivíduos ou entidades autorizadas tenham acesso a recursos e informações sensíveis. A autenticação envolve validação das credenciais apresentadas por um usuário ou sistema, como nome de usuário e senha, para confirmar sua identidade. Existem várias formas de autenticação, como:

- **Autenticação por senha:**
 - Mais comum. Nome de usuário atrelado à senha, e assim é verificado a identidade;
 - Sujeito a ataques de força bruta e esquemas de **Phishing**.
- **Autenticação de dois fatores ou multifator:**
 - Acrescenta uma camada adicional de segurança ao exigir que os usuários forneçam uma segunda forma de autenticação além de suas senhas;
 - Pode incluir códigos gerados por aplicativos, SMS, tokens, ou até reconhecimento biométricos.

- **Certificados digitais:**

- Baseados em chaves públicas, eles garantem a identidade de um usuário ou sistema por meio de chaves criptográficas.

- **Autenticação biométrica:**

- Utiliza características físicas únicas, como impressões digitais, reconhecimento facial ou de voz para verificar a identidade dos usuários.

Figura 3: Autenticação de dois fatores ou multifator



Fonte: Mercado Bitcoin. Disponível em: <https://www.mercadobitcoin.com.br/economia-digital/tecnologia/o-que-e-2fa/>. Acesso em: 26 jan. 2024.

3. Conscientização de Segurança

Uma das principais táticas de proteção e segurança da informação é o trabalho de conscientização sobre ela, seja em âmbito pessoal ou ambiente corporativo. Essa conscientização envolve a educação e a promoção de boas práticas de segurança para indivíduos e organizações, visando criar uma cultura de segurança. Vamos explorar mais detalhadamente a conscientização de segurança em ambos os contextos.

3.1. Âmbito Pessoal

O primeiro passo que todos devem dar em direção a segurança é o mais simples: melhores e mais complexas senhas! Senhas fortes que contenham variações de caracteres, como maiúsculas e minúsculas, letras e números, caracteres especiais, senhas únicas para cada

tipo de acesso e, é claro, evitar senhas óbvias, como datas de aniversário ou coisas do gênero. Os ataques a senhas funcionam geralmente por força bruta. Atualmente, os ataques são sofisticados o suficiente para primeiro utilizar senhas prováveis, como 1234 ou então tentativas customizadas especificamente para o login específico que quer se atacar. Vale repetir a importância da autenticação de dois fatores, por mais que seja complexo precisar de um código enviado por SMS, este processo garante uma camada bem valiosa de proteção aos seus dados.

Atualmente, um dos métodos mais comuns de ataques no âmbito pessoal é o que popularmente chamamos de golpes digitais ou **Phishing**. Tradicionalmente, estes golpes são feitos por meio de e-mails e tentam enganar os destinatários para que revelem informações pessoais ou cliquem em links maliciosos. A versão mais famosa deste golpe atua via aplicativos de mensagem instantânea, como o WhatsApp. Nestes golpes, os criminosos podem se passar como uma empresa, órgão do governo, ou até mesmo como um amigo ou parente seu, geralmente prometendo fortunas, pedindo ajuda ou outros métodos fraudulentos feitos para te afetar e roubar seu dinheiro ou informações de alguma forma ou de outra.

É necessário se certificar que a pessoa que você está falando online é de fato quem ela diz ser; ligações e chamadas de vídeo costumam ser bons métodos para garantir esta parte. Deve-se ficar atento à gramática e estrutura de mensagens suspeitas, pois, muitas vezes, os criminosos se passando por empresas e órgãos oficiais cometem erros inaceitáveis nestas instituições. Caso ele esteja se passando por um conhecido seu, fique atento aos padrões de fala e escrita, veja se está digitando da mesma forma que seu conhecido faria.

Muitas vezes, neste ataque mais pessoal, onde se fingem de conhecidos, os criminosos utilizam imagens e informações privilegiadas mineradas pelas redes sociais. Por isso, é importante também ficar atento ao que se coloca disponível em suas redes sociais, para que informações não caiam nas mãos erradas.

Por fim, se faz necessário o apelo pelas atualizações de software e utilização de antivírus em dia. A maior parte das atualizações dos softwares mais comumente utilizados são feitas por dois motivos:

- Maior eficiência nos seus processos internos;
- Maior segurança de um jeito ou de outro, normalmente não especificado.

Muitos ataques exploram falhas não corrigidas, então, o hábito de adiar atualizações o máximo possível, que muitos de nós somos culpados em fazer, é, na verdade, bastante irresponsável dentro do mundo de segurança de informação. Cabe a cada um buscar conhecimento que traga mais segurança para nossas vidas.

3.2. Ambiente Corporativo

Já no ambiente corporativo, esta responsabilidade, quanto ao conhecimento de segurança, cabe à própria empresa. É necessário que a empresa faça regularmente treinamentos de funcionários sobre boas práticas e segurança, incluindo como reconhecer ameaças como **Phishing** e como agir em casos de incidentes. A empresa deve ter bem estabelecidas políticas de segurança de dados. Estas devem ser claras e comunicadas a todos os funcionários, definindo responsabilidades e consequências para o não cumprimento das mesmas.

Políticas de controle de acesso devem ser implementadas juntamente de sistemas de monitoramento de rede e de detecções de ameaças, capazes de identificar atividades suspeitas e, então, responder prontamente a incidentes.

Do funcionário mais recente, com menos acesso ao CEO, todos devem ser conscientizados da segurança; basta uma fraqueza ou uma falha humana para uma pessoa mal-intencionada ser capaz de efetuar um ataque ou acesso indevido. Testes de invasão, testes de **Phishing** e rotação de senhas são alguns exemplos básicos do que a empresa pode fazer como um todo para melhorar a segurança de seus dados.

Vale ressaltar que a conscientização da segurança da informação não é um evento único, mas um processo contínuo. Ela ajuda a reduzir o risco de violações de segurança, protege informações confidenciais e contribui para a construção de uma cultura organizacional de segurança. Tanto no âmbito pessoal quanto no ambiente corporativo, a educação e a conscientização desempenham um papel crucial na prevenção de ameaças cibernéticas.

Considerações Finais da Aula

Na era digital, em constante evolução, a segurança da informação tornou-se um pilar essencial para proteger nossos dados e sistemas críticos. Ao explorar a história da segurança da informação, desde os primórdios da criptografia até a era moderna da tecnologia da informação, podemos apreciar a longa jornada que a segurança percorreu.

O “triângulo mágico” da confidencialidade, integridade e disponibilidade continua a ser o alicerce sobre o qual construímos nossa estratégia de segurança. A confidencialidade protege nossos segredos, a integridade garante a precisão de nossos dados e a disponibilidade mantém nossos sistemas acessíveis quando mais precisamos.

Além disso, a conscientização de segurança ao nível pessoal e corporativo é a chave para fortalecer nossas defesas cibernéticas. Educar indivíduos sobre práticas seguras e

cultivar uma cultura de segurança nas empresas são alicerces sólidos para proteger contra ameaças em constante evolução.

Neste cenário, em rápida mutação, é imperativo que continuemos a aprender, nos adaptar e investir em segurança da informação. Somente assim estaremos preparados para enfrentar os desafios e oportunidades do mundo digital em constante expansão. A segurança da informação é uma jornada contínua, e nossa vigilância e compromisso com ela são a chave para proteger nossos ativos mais valiosos.

Material Complementar



Centro de Estudos, Resposta e Tratamento de Incidentes de Segurança no Brasil

2024, CERT.

Site que divulga as melhores práticas na área de gestão de segurança da informação.

Disponível em: <https://www.cert.br/>. Acesso em: 26 jan. 2024.

Referências

BARRETO, Jeanine dos Santos *et al.* **Fundamentos de segurança da informação**. Porto Alegre: SAGAH, 2018.

CARTILHA de Segurança para Internet. **CERT.br**, 2024. Disponível em: <https://cartilha.cert.br/>. Acesso em: 1º ago. 2023.

CARTILHA de Segurança para Internet para crianças. **CERT.br**, 2024. Disponível em: <https://internetsegura.br/criancas/>. Acesso em: 1º ago. 2023.

MORAES, Alexandre Fernandes de. **Segurança em redes: fundamentos**. São Paulo: Érica, 2010.